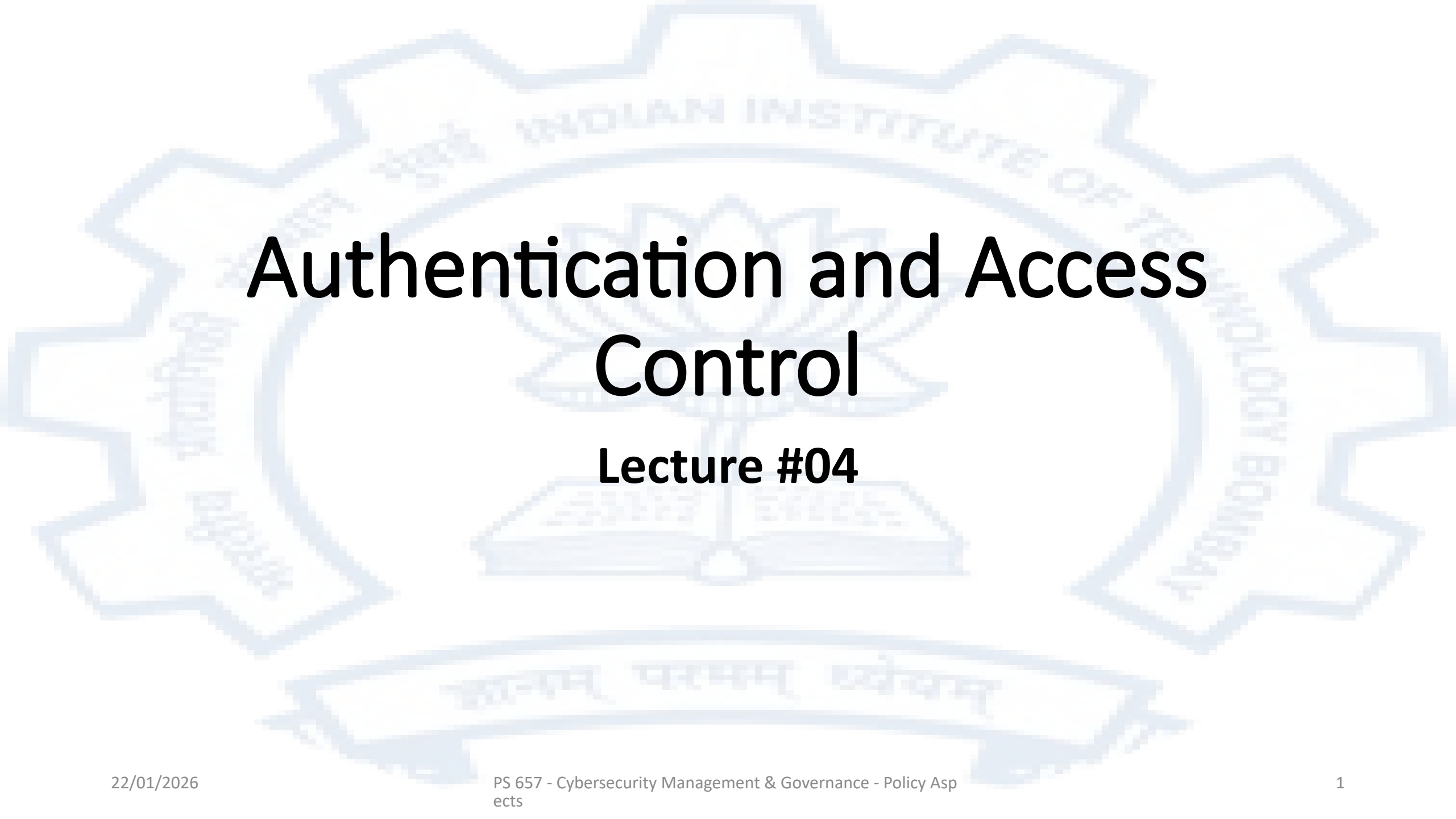


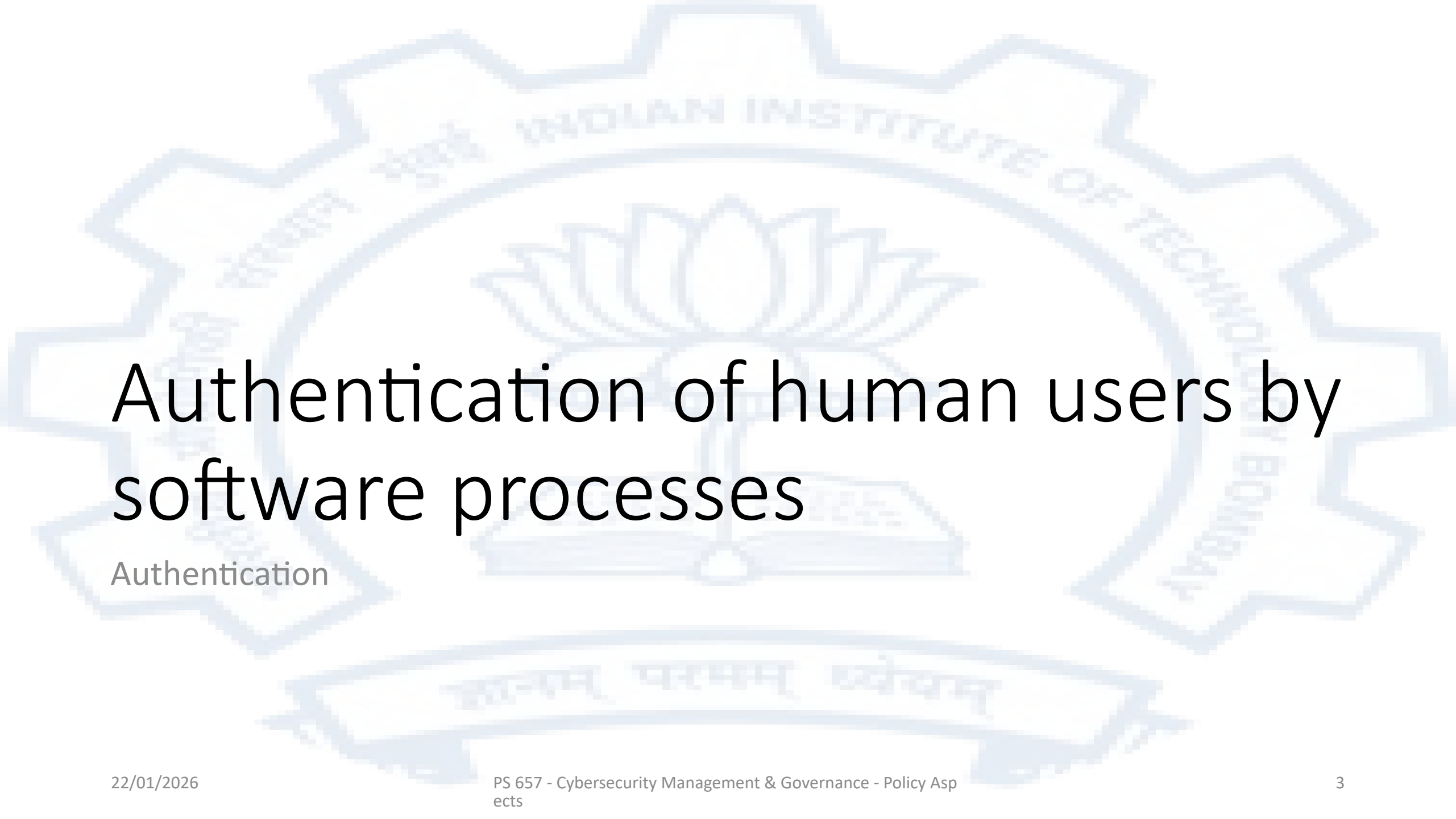


Authentication and Access Control

Lecture #04

Authentication

- Authentication could be
 - Entity Authentication
 - Source Authentication
- Source Authentication deals with the integrity and creation of data
- Entity Authentication deals with an entity (person or software process) proving that it is who it claims to be to another software process
- This lecture deals with entity authentication

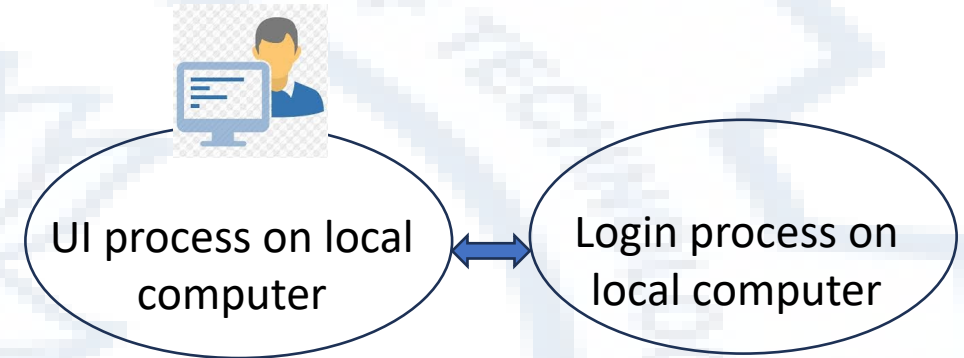
The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is a gear-like shape with a lotus flower in the center. The text "INDIAN INSTITUTE OF TECHNOLOGY" is written in a circular path around the lotus, and "BOMBAY" is written at the bottom. There is also text in Hindi at the bottom of the logo.

Authentication of human users by software processes

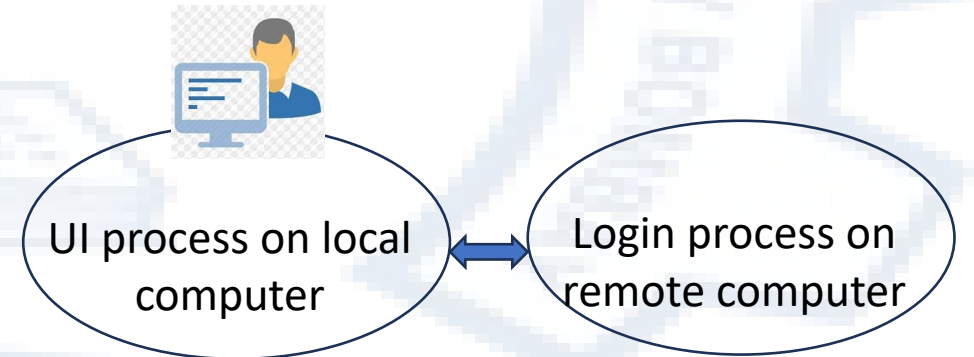
Authentication

Human user authenticating to computer system

Scenario 1: Human user
Authenticating to a local
computer



Scenario 2: Human user
Authenticating to a remote
computer



Possible methods of authentication

- Based on what you know
- Based on what you have
- Based on what you are

Simple password based authentication

- The user and the server on which the login process is running both share a secret. This secret is presented by the user to the login process. If it matches with what the server has stored then the user is authenticated else not
- This is a simple and easy to implement scheme
 - Users can self register and choose their own passwords
 - Users can change their own passwords

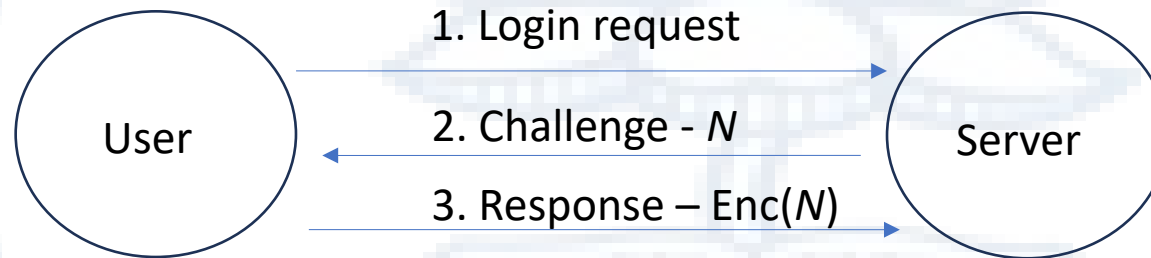
Issues with simple password based authentication

- If the password is not long enough it can be brute-forced
- If the password is sent over a network it can become known to an eavesdropper
- Since a password is forgotten there is the need to have a forgot password functionality. How will a user be authenticated if the password itself has been forgotten?
- If an adversary has access to the database of stored passwords on the server then that adversary can access any user's account

Practical methods of addressing issues with simple password based authentication

- Password policies enforce a certain length and complexity for passwords (eg. Min 12 characters with at least 1 uppercase, 1 lowercase, 1 digit and 1 special character)
- While first time registration of the user is being carried out some additional secret(s) such as mother's maiden name or the answers to some questions are also stored, and these can be used to authenticate a forgot password request
- To address the issue of an adversary having access to the stored secrets (passwords, answers to questions etc.) the technique usually used is to store a hash of the secret, and whenever a secret is received the login process will compute the hash and match it with the stored hash

Cryptographic authentication

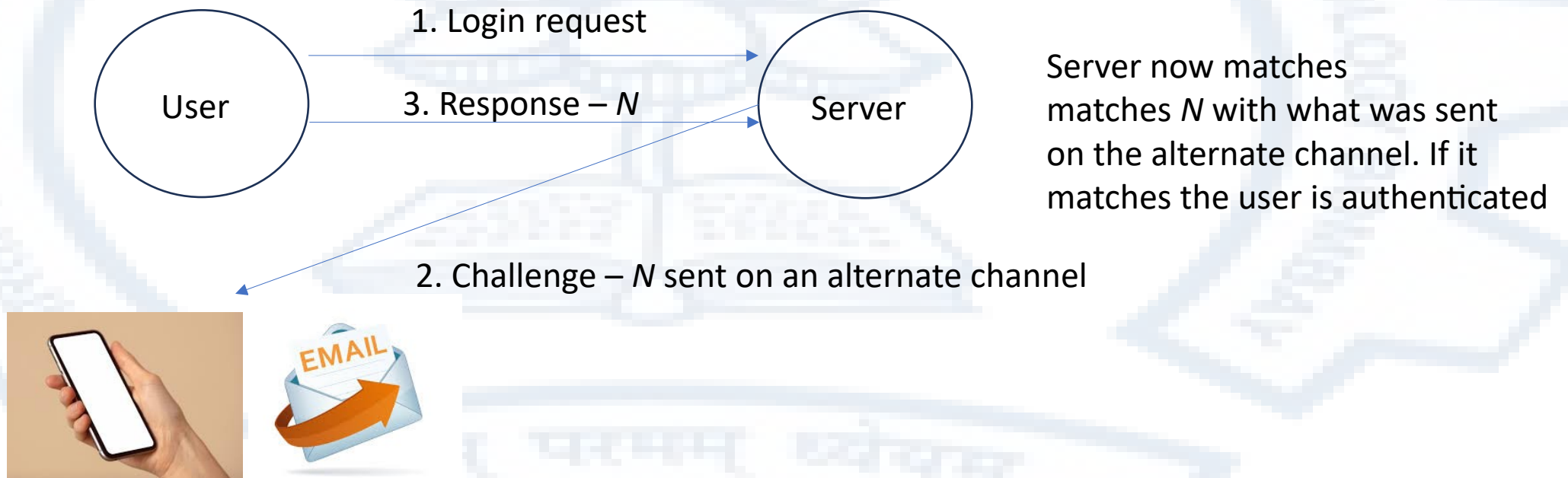


Server now computes $\text{Dec}(\text{Enc}(N))$. If this matches N the user is authenticated

This can be implemented either by

- A symmetric system, in which case each user and the server need to share a secret key
- A public key system, in which case each user has their own private key and the server has their public key

Alternate channel authentication



TOTP and HOTP

- Both these schemes are based on both the user and the server being able to run a computation with a shared but static seed and a varying factor
 - In the case of HOTP this varying factor is a counter which is incremented by both the server and user after each login attempt
 - In the case of TOTP this varying factor is the current time
- The user computes an OTP and sends it to the server. The server shares the same seed and knows how the varying factor is to be computed so it is also able to independently compute and verify the OTP

Multifactor authentication

- When the user has more than one physically distinct device (one of which is the computer that the user is using to login) and some part of the computation of the response or receipt of an OTP is on a device that is physically distinct from the computer that the user is using to login, then this type of scenario ensures that the user possesses something specific in addition to knowing something specific. This type of authentication is often called multifactor authentication

Biometric Authentication

- Authentication based on who you are
- There are two types
 - Behavioural – keystroke dynamics, signature dynamics etc....
 - Physiological – Fingerprint, palm geometry, facial recognition, iris recognition
- Fingerprint and Facial recognition are by far the most commonly deployed techniques

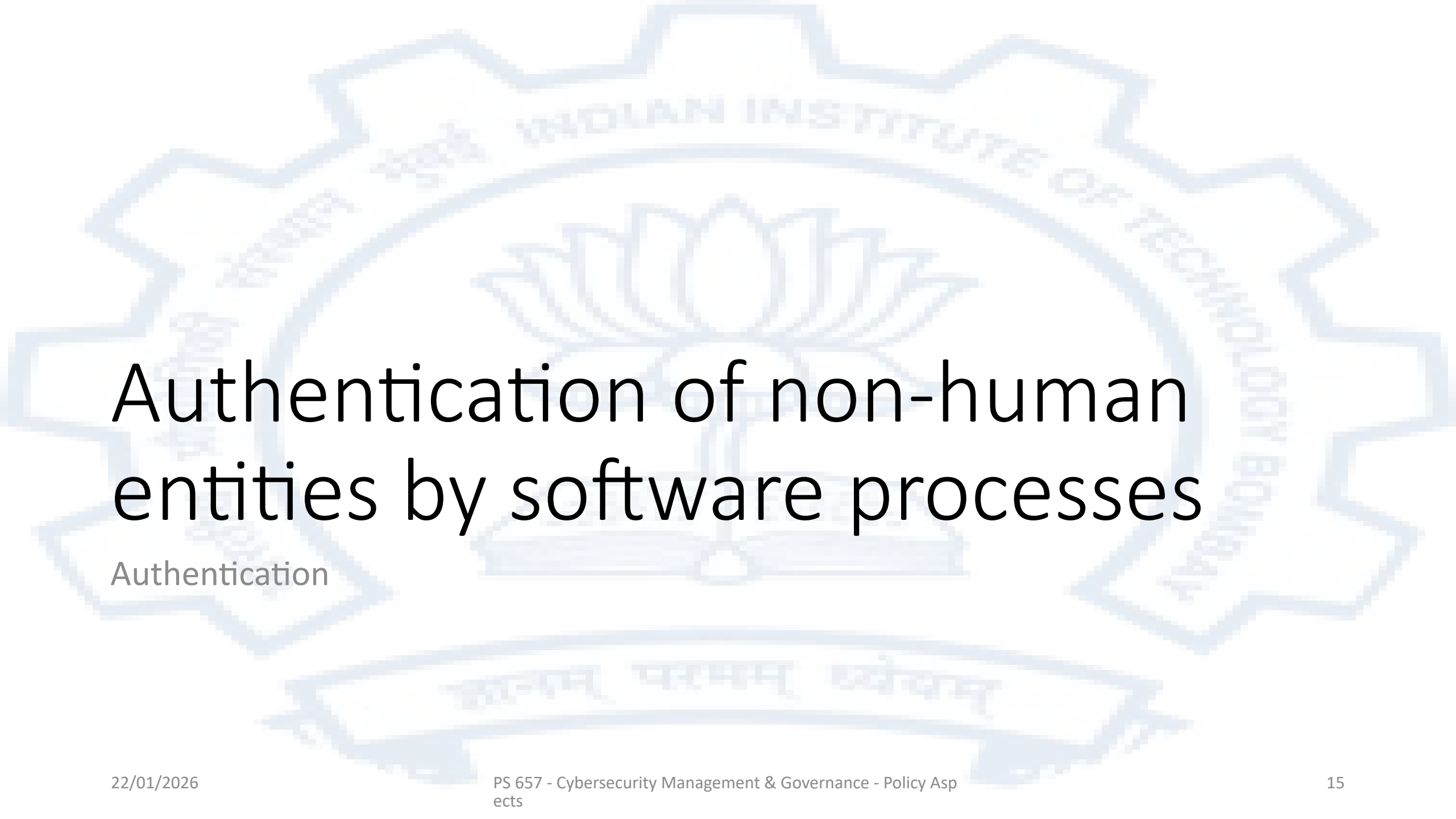
Biometric replay attacks



If the biometric sensor and the matching unit are integrally one unit and there is no storing of the biometric, such a system can be given a high level of trust



If the biometric sensor captures biometric data and sends it to a matching unit over a network then the biometric system is vulnerable to replay attacks and significant care has to be taken to protect against replay attacks.

The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is a gear-like shape with a lotus flower in the center. The text "INDIAN INSTITUTE OF TECHNOLOGY" is written along the top inner edge of the gear, and "BOMBAY" is written along the bottom inner edge. The lotus flower has five petals.

Authentication of non-human entities by software processes

Authentication

Non-human entities

- Some type of non-human entities
 - Servers
 - Network devices
 - IoT devices
- In all cases there is some software running on the device which is acting on behalf of the device
- The problem in all cases is how can a software process authenticate another software process that is running without any user interaction

Authentication of software processes

- All current methods finally rely upon storing a shared secret
 - In the case of simple password schemes, both processes will have to know the same password
 - In the case of symmetric key based authentication, both processes will have to know a shared secret key
 - In the case of public key based authentication the device/software process will be associated with a public key and a private key and the software process requesting authentication will need access to a secret private key
- Keeping this secret information secure is a significant challenge

Software can't keep secrets

The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay logo. The logo is circular with a gear-like outer border. Inside the circle, there is a lotus flower in the center, and text in English and Sanskrit. The English text reads "INDIAN INSTITUTE OF TECHNOLOGY BOMBAY". The Sanskrit text at the top is "विद्या ऽ मृतमश्नुते" and at the bottom is "सत्यम् धर्मम् विजयते".

Access Control

Access Control

Access Control

Access control is the process of granting or denying access for specific requests to a resource by an entity requesting access.

Making the decision to grant access is based on the following factors

- What is the entity requesting access
- What is the resource being requested and what sort of usage is being requested
- What are the rules by which such decisions are to be made

Security policies

- The general rules that determine how sensitive organizational resources should be used are referred to as security policies but also more specifically known as organizational security policies.
- The rules enforced by IT systems on the resources that they control are also called security policies but more specifically called automated security policies
- Subjects are entities that may request resources. Users and processes are examples of subjects
- Objects are the resources that subjects request access to. Files, memory, printers are examples of objects
- Access rights or privileges are permissions to access a particular object in a specific manner. Each object has an Access Control List (ACL) which describes who is allowed to do what
 - For example every file in unix like systems is associated with a few bits that describe how the owner, group and others may access it `rw-rw-rw-`

Role Based Access Control

- A role is an intermediate entity between subjects and objects
- A role is associated with permissions to carry out certain types of operations with well defined integrity checks and this mediates the actual access to objects (ACLs may contain roles)
- Role based access control has several variants
 - Flat RBAC
 - Each role is individually created and given permissions
 - Hierarchical RBAC
 - Provides support for role hierarchies
 - Constrained RBAC
 - Provides support for separation of duties (SoD).
 - *SoD refers to the principle that no user should be given enough privileges to misuse the system on their own. For example, the person authorizing a demand draft should not also be the one who can prepare them. Separation of duties can be enforced either statically (by defining conflicting roles, i.e., roles which cannot be executed by the same user) or dynamically (by enforcing the control at access time). An example of dynamic separation of duty is the two-person rule. – source NIST*

Attribute Based Access Control

“logical access control methodology where authorisation to perform a set of operations is determined by evaluating attributes associated with the subject, object, requested operations, and, in some cases, environment conditions against policy, rules, or relationships that describe the allowable operations for a given set of attributes”

- Attributes need not be limited to the user-id or the role assigned to the user and nor are these specific attributes given a special place or even required*
- Access control may be performed in an application or in the infrastructure supporting the application. Access control in an infrastructure uses generic attributes and operations. Access control in an application uses application-specific attributes and operations. In this distinction, ABAC can be viewed as a synonym for application-level access control.*

Code Based Access Control

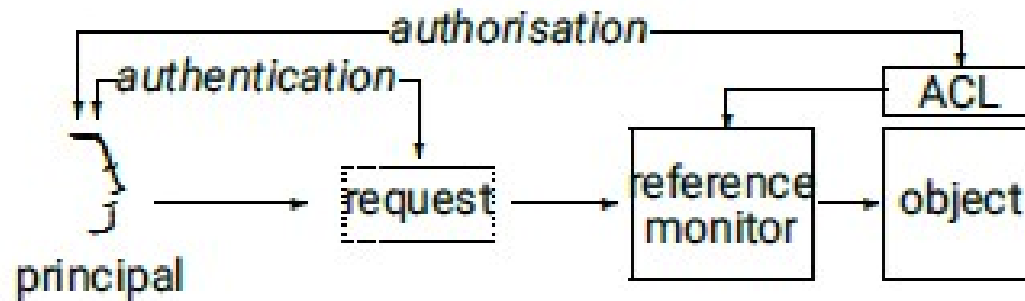
In Code Based Access Control executables are assigned access rights. These rights may be assigned based on several attributes of the code itself rather than the attributes of a user that has launched the code. Possible attributes are

- Hash value of the executable
- A digital signature of the code
- A tag identifying the publisher of the code

Mobile Phone Security

- Smartphones are typically owned and used by a single user
- The objects for access control are the private data on the phone and sensitive functions as well as the integrity of the smartphone systems
- The subjects for access control are the apps that are installed on the phone
- As an example the Android system groups permissions into three groups
 - Normal – Apps do not need approval
 - Dangerous – Apps need user approval (Till Android 6.0 these were requested at installation but now these are requested when first used)
 - Signature – Only the platform provider can approve

Reference Monitor



Cybersecurity CyBOK v 1.1.0

- A reference monitor performs two main tasks
 - It authenticates any evidence provided by a subject in respect of an access request
 - It evaluates the request based upon the security policy to determine if it should be granted
- In the original definition the reference monitor was an abstract machine, the security kernel was the trusted implementation and the Trusted Computing Base was the sum total of all the security mechanisms. In more recent times the term TCB has been used to refer to the security kernel

Digital Rights Management

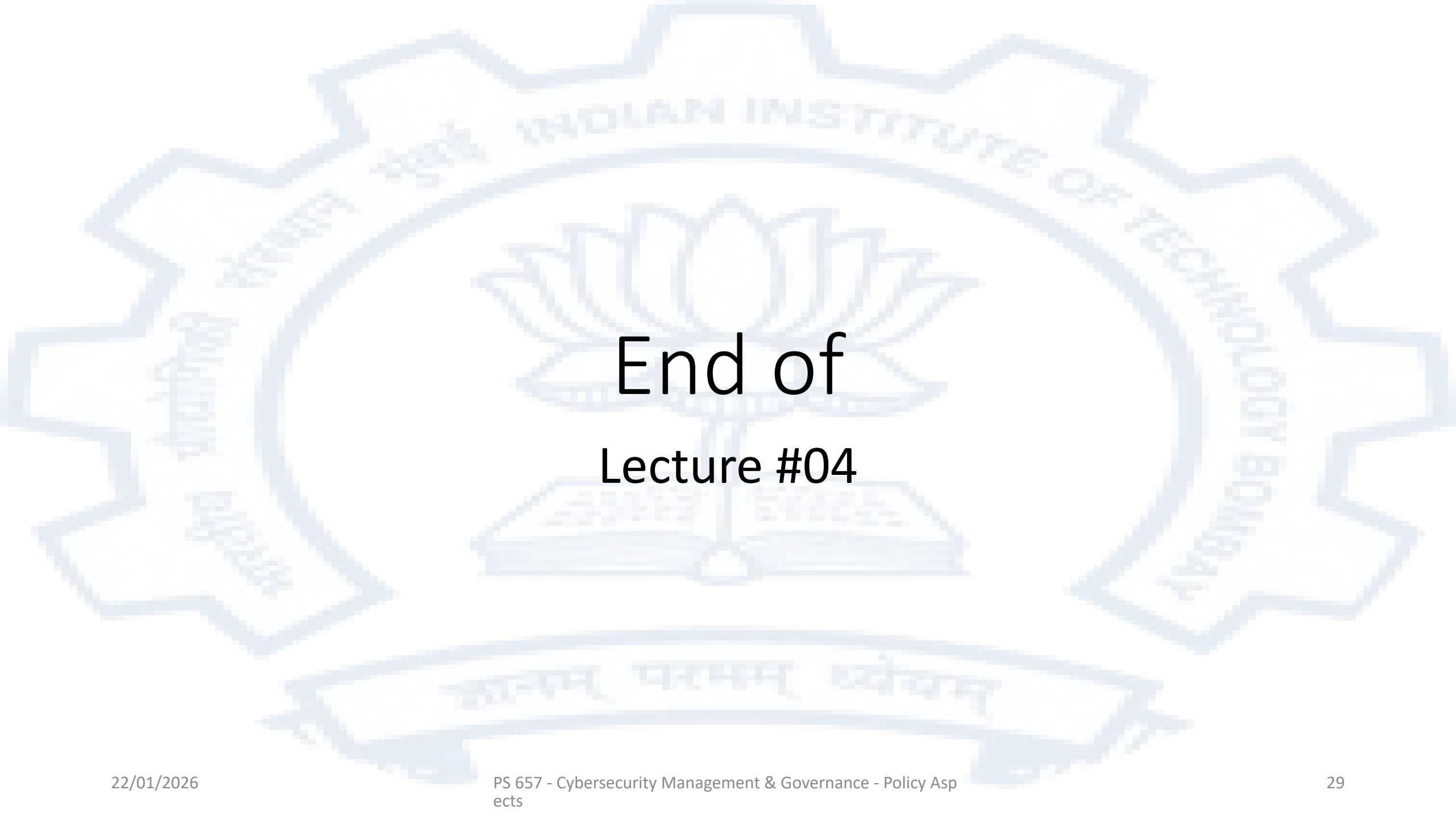
- Originated in the entertainment industry to protect the content of publishers
 - Games, Movies , Music (and to some extent software)
- The focus here is on protecting an external parties content from the owner or user of a computer system. This is in contrast to the traditional usage of access control to protect a system from external parties
- The concept of superdistribution involves wrapping content into secure containers which can be freely distributed. In order to use the content some additional information is required which will unpack the content and render it usable

Some Modern Mechanisms for the support of access control

- Modern hardware extensions for memory protection
 - Memory protection keys MPK
 - Memory Tagging Extensions MTE
 - Software Guard Extensions (SGX)
- Secure Platforms
 - HSMs
 - Smartcards
 - Secure elements
- Trusted Platform Module
 - Root of trust for measurement (RTM)
 - Root of trust for storage (RTS)
 - Root of trust for reporting (RTR)

To summarize

- Authentication and access controls are basic security functions
- The purpose of authentication is to determine if an entity is who or what it claims to be based on information provided by that entity
- There are various techniques of authentication and most require both the requester and verifier to maintain some long term secret
- Once a requester has been authenticated, the relevant security policies that are applicable are used to decide if the request should be granted
- Access Control refers to the mechanisms that are required to make sure that only authenticated and authorized request are granted access
- Access Control that relies purely on software cannot achieve a very high degree of protection
- The highest level of protection is through use of specialized hardware features that can be leveraged by the OS or applications to make sure that an unauthorized access is not possible

The background of the slide features a large, light blue watermark of the Indian Institute of Technology Bombay (IIT Bombay) logo. The logo is circular with a gear-like outer border. Inside the circle, there is a lotus flower in the center, and a banner at the bottom with the Sanskrit motto 'सत्यम् धर्मम् विद्यम्' (Satyam Dharmam Vidyam). The text 'INDIAN INSTITUTE OF TECHNOLOGY BOMBAY' is written along the inner circle.

End of Lecture #04